SECURITY POLICY
DEVELOPMENT
Using ISO 27001 & SANS Institute Templates

UK Healthcare Clinical & Administrative Centre • Cybersecurity Analyst Methodology • 6 Usable Policies Produced

UK GDPR • DATA PROTECTION ACT 2018 • ISO 27001:2022 • SANS Policy Templates • Risk-Driven • Audit-Ready

ISO 27001	SANS	6	UK GDPR	HELATH DATA
Primary Template Framework	Secondary Template Source	Usable Policies Produced	Regulatory Compliance Target	Primary Asset Protected

Date: 11 October 2026

Table of Contents

1. Executive Summary, The Analyst's Approach3
2. The Template Selection Decision4
3. ISO 27001 Template Structure, How It Was Used5
4. SANS Template Structure, How It Was Used6
5. Template Customisation: ISO 27001 and SANS in a UK Healthcare Context7
6. Risk Register, Driving Policy Selection8
7. Policy 1, Health Data Access Control Policy (SEC-POL-001)9
8. Policy 2, Health Data Encryption Policy (SEC-POL-002)13
9. Policy 3, Authentication & Password Policy (SEC-POL-003)16
10. Policy 4, Audit Logging & Monitoring Policy (SEC-POL-004)19
11. Policy 5, Breach Notification Policy (SEC-POL-005)22
12. Policy 6, Acceptable Use Policy (SEC-POL-006)25
13. ISO 27001 Annex A Control Mapping, All 6 Policies28
14. Policy Suite Implementation Plan29
15. Key Lessons, What the Analyst Learned30
16. Screenshot Evidence Index31

1. Executive Summary, The Analyst's Approach

As the Cybersecurity Analyst assigned to the UK Healthcare Clinical & Administrative Centre, I was tasked with developing a complete and usable suite of information security policies to protect personal data, health information and critical organisational systems. The policies were developed to support compliance with the UK General Data Protection Regulation (UK GDPR), the Data Protection Act 2018 and recognised information security practices.

Rather than developing each policy entirely from scratch, I used ISO 27001:2022 as the primary information security framework and SANS policy templates as a secondary source for policy structure and content. This approach provided a recognised control framework while allowing each policy to be customised to the organisation’s healthcare environment, operational risks and security requirements.

Starting with established frameworks served three important purposes. First, it promoted consistency and completeness by ensuring that each policy contained essential sections such as purpose, scope, responsibilities, policy requirements, compliance and enforcement. Second, it allowed the policies to be mapped to relevant ISO 27001:2022 Annex A controls, improving traceability and audit readiness. Third, it reduced development time without compromising quality, enabling the analyst to focus on adapting each policy to the risks associated with health data and other special-category personal data.

The outcome of this process is a suite of six usable security policies: a Health Data Access Control Policy, Electronic Health Data Encryption Policy, Authentication and Password Policy, Audit Logging and Monitoring Policy, Personal Data Breach Notification Policy, and Acceptable Use Policy. Each policy is aligned with the organisation’s risk register and applicable UK data-protection requirements and can be issued to staff, published on the organisational intranet and reviewed as part of an internal security or compliance audit.

2. The Template Selection Decision

Before beginning the policy-development process, I evaluated several recognised framework and template sources. The key question was: which source provides the appropriate structure, level of detail and recognised framework alignment for a UK healthcare organisation subject to the UK GDPR and Data Protection Act 2018?

2.1 Templates Evaluated

Template Source	Format	Best For	Decision
ISO 27001:2022	Annex A control framework, maps controls to policy requirements	Compliance-driven policies with clear control mapping and audit trail	**SELECTED** — Primary framework. Used to structure all six policies around relevant ISO 27001:2022 Annex A controls and provide an internationally recognised foundation for information security governance and audit readiness.
SANS Institute	Free downloadable policy templates at sans.org/information-security-policy	Practical, plain-language policies with clear enforcement and scope sections	**SELECTED** — Secondary template source. Used for practical policy language, clause structure and the Overview/Purpose/Scope/Policy/Compliance/Revision format. Best suited to producing clear policies that employees can understand and follow.
NIST SP 800-53	US Federal controls framework, extensive technical control catalogue	Organisations requiring a comprehensive catalogue of detailed security and privacy controls	**NOT SELECTED as the primary framework.** NIST SP 800-53 provides a comprehensive catalogue of security and privacy controls and was retained as supplementary guidance for technical safeguards, access control, audit logging, incident response and risk management.
CIS Controls v8	18 prioritised security controls with implementation groups	Operational security controls for smaller organisations	NOT SELECTED as primary, but CIS Controls 5 (Account Management) and 8 (Audit Log Management) were referenced as supplementary guidance for specific policy clauses.

Analyst Note: *I selected ISO 27001:2022 as the primary framework because it provides an internationally recognised, risk-based structure for establishing and maintaining an information security management system. Mapping the policies to relevant Annex A controls improves traceability, consistency and audit readiness. SANS was selected as the secondary template source because its practical policy language and established structure are suitable for both technical and non-technical staff. NIST SP 800-53 and CIS Controls v8 were used as supplementary guidance to strengthen the policies with detailed security, privacy and implementation controls.*

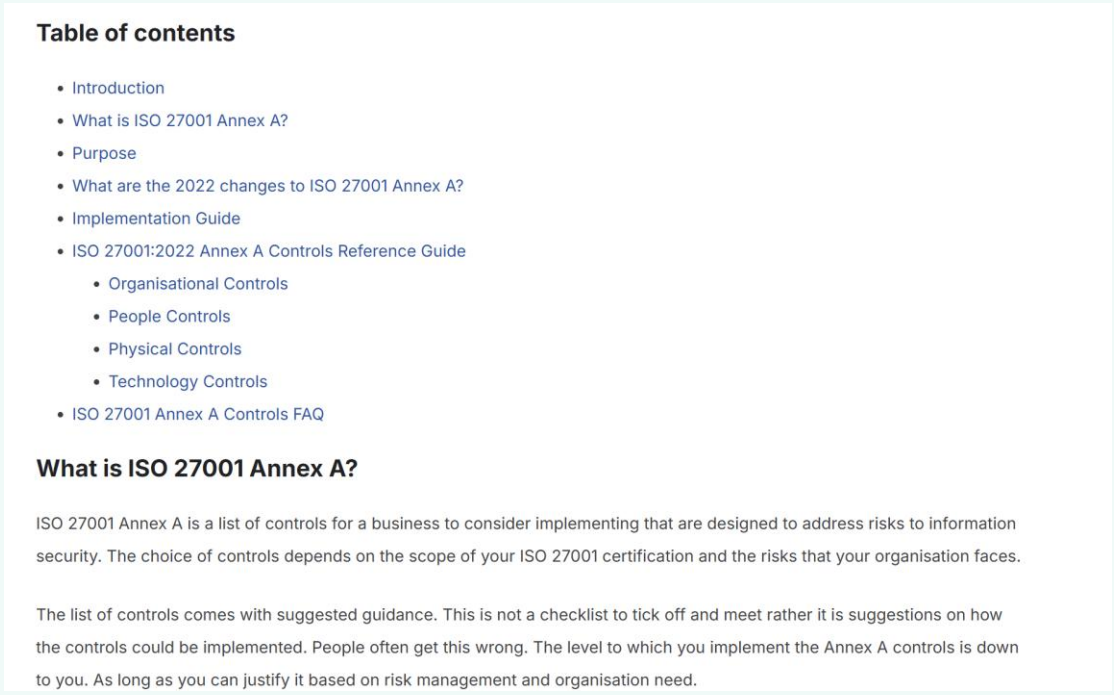


Table of contents

- Introduction
- What is ISO 27001 Annex A?
- Purpose
- What are the 2022 changes to ISO 27001 Annex A?
- Implementation Guide
- ISO 27001:2022 Annex A Controls Reference Guide
  - Organisational Controls
  - People Controls
  - Physical Controls
  - Technology Controls
- ISO 27001 Annex A Controls FAQ

What is ISO 27001 Annex A?

ISO 27001 Annex A is a list of controls for a business to consider implementing that are designed to address risks to information security. The choice of controls depends on the scope of your ISO 27001 certification and the risks that your organisation faces.

The list of controls comes with suggested guidance. This is not a checklist to tick off and meet rather it is suggestions on how the controls could be implemented. People often get this wrong. The level to which you implement the Annex A controls is down to you. As long as you can justify it based on risk management and organisation need.

Figure 1: ISO 27001:2022 Annex A controls and implementation guidance. Source: The High Table Global Ltd (n.d.).

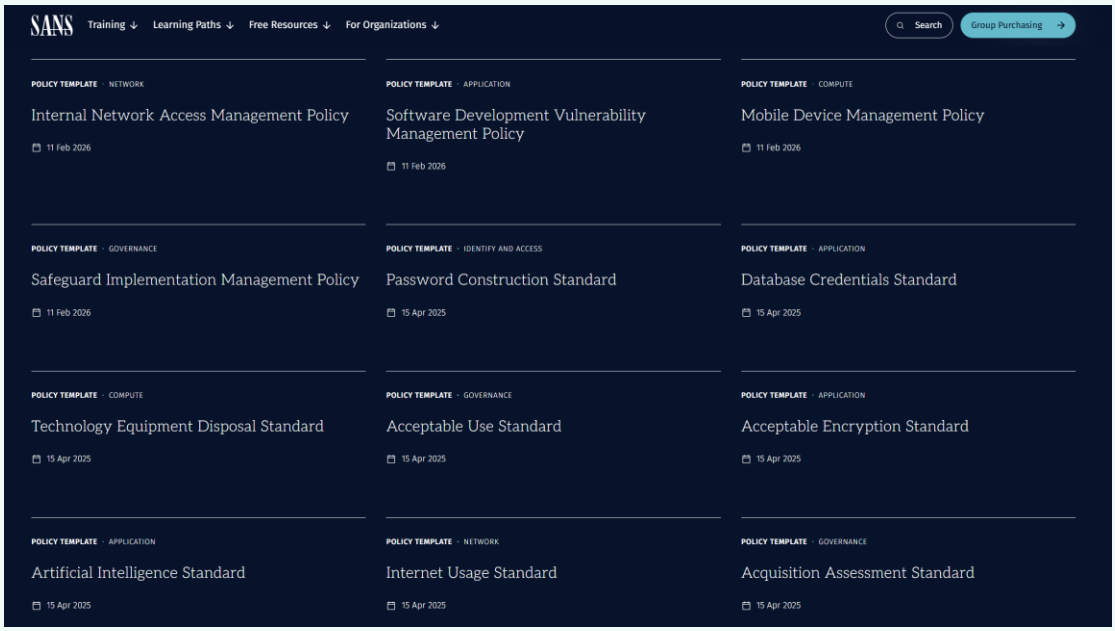


Figure 2: SANS cybersecurity policy-template library used as the secondary template source. Source: SANS Institute (2026).

3. ISO 27001 Template Structure: How It Was Used

ISO 27001:2022 Annex A contains 93 information security controls organised into four categories: Organisational Controls (A.5), People Controls (A.6), Physical Controls (A.7), and Technological Controls (A.8). My approach was to map the risks identified during the risk assessment to the relevant Annex A controls and then use those controls to establish appropriate requirements for each policy document.

3.1 ISO 27001 Annex A Controls Used in This Policy Suite

Control	Control Name	Category	Policy It Drives
A.5.1	**Policies for Information Security**	Organisational	All 6 policies, the overarching policy management framework
A.5.15	**Access Control**	Organisational	Policy 1, Health Data Access Control Policy
A.5.16	**Identity Management**	Organisational	Policy 1, Health Data Access Control Policy
A.5.17	**Authentication Information**	Organisational	Policy 3, Authentication & Password Policy
A.5.24	**Information Security Incident Management Planning and Preparation**	Organisational	Policy 5, Breach Notification Policy
A.6.3	**Information Security Awareness, Education and Training**	People	Policy 6, Acceptable Use Policy (training requirement)
A.8.2	**Privileged Access Rights**	Technological	Policy 1, Health Data Access Control Policy (RBAC)
A.8.5	**Secure Authentication**	Technological	Policy 3, Authentication & Password Policy
A.8.11	**Data Masking**	Technological	Policy 2, Health Data Encryption Policy
A.8.12	**Data Leakage Prevention**	Technological	Policy 2, Health Data Encryption Policy
A.8.15	**Logging**	Technological	Policy 4, Audit Logging & Monitoring Policy
A.8.16	**Monitoring Activities**	Technological	Policy 4, Audit Logging & Monitoring Policy
A.8.24	**Use of Cryptography**	Technological	Policy 2, Health Data Encryption Policy

3.2 ISO 27001 Policy Document Structure

ISO 27001 does not prescribe a specific format for individual policy documents. However, its management-system requirements and Annex A controls identify information that must be governed and documented. I combined these requirements with the practical structure of the SANS policy templates to create the consistent format used across all six policies.

Policy Section	Content Required
Purpose / Intent	Explains why the policy exists and identifies the risks and security objectives it addresses.
Scope	Defines who, what and where the policy applies, supporting the ISMS scope established under ISO 27001 Clause 4.3.
Definitions	Defines important terminology to support consistent understanding and implementation.
Policy Statements	Establishes the mandatory requirements and maps them to relevant ISO 27001 Annex A controls.
Roles & Responsibilities	Identifies accountability for implementing, maintaining and enforcing the policy, supporting ISO 27001 Clause 5.3.
Compliance & Enforcement	Explains how compliance will be monitored and how violations will be addressed, supporting Annex A control 5.36.
Related Documents	Cross-references associated policies, standards, procedures and supporting records.
Review & Approval	Records policy ownership, approval and review requirements, supporting Annex A control 5.1 and ISO 27001 Clause 5.2.

4. SANS Template Structure: How It Was Used

The SANS Institute provides a library of free, downloadable cybersecurity and information security policy templates. I selected the templates most relevant to the healthcare organisation's risk register and used their practical structure as the foundation for the six policies. Each template was customised to reflect UK GDPR, the Data Protection Act 2018, ISO 27001:2022 controls, healthcare operations and the organisation's segmented network environment.

4.1 SANS Templates Downloaded & Applied

SANS Template	Used For	How It Was Customised
Information Security Policy	**Foundation for all 6 policies**	Replaced the generic organisation name with 'Healthcare Clinical & Administrative Centre'; added UK GDPR, Data Protection Act 2018 and ISO 27001:2022 requirements; added health-data handling and VLAN network context.
Acceptable Use Policy	**Policy 6, Acceptable Use**	Retained the SANS structure; added requirements for health-data handling, clinical workstations, approved devices, remote working and visitor VLAN restrictions and the staff Wireless network.
Password Protection Policy	**Policy 3, Authentication & Password**	Extended the SANS authentication requirements by adding mandatory MFA, stronger controls for privileged and clinical-system accounts, and alignment with NIST authentication guidance.
Data Classification Policy	**Asset classification in all policies**	Replaced the US-focused classifications with Public, Internal, Confidential and Restricted classifications; identified health data as special category data and added UK GDPR handling requirements.
Security Response Plan Policy	**Policy 5, Breach Notification**	Added UK GDPR breach-assessment procedures, ICO notification within 72 hours where required, communication with affected individuals where there is a high risk, and incident-recording requirements.
Audit Policy	**Policy 4, Audit Logging**	Extended the audit scope to cover access to health data, privileged activity and security events; added risk-based log-retention requirements and alignment with ISO 27001 controls A.8.15 and A.8.16.

4.2 SANS Policy Template Format Used in This Project

SANS Section	Content
1. Overview	High-level context, why this area of security matters. Written in plain language for non-technical readers.
2. Purpose	Specific aim of this policy, what risk or requirement it addresses.
3. Scope	Who the policy applies to, roles, departments, contractors, locations.
4. Policy	The numbered, actionable policy requirements, what staff must or must not do.
5. Policy Compliance	Consequences of non-compliance, disciplinary action, regulatory reporting, termination.
6. Related Standards, Policies, Processes	Cross-references to other relevant policies and standards.
7. Definitions and Terms	Definitions of technical, legal or organisational terms used within the policy.
8. Revision History	Version control, date, version number, description of change, approver.

5. Template Customisation: ISO 27001, SANS and UK Healthcare Context

The most important part of using templates is knowing what to keep, what to change, and what to add. A policy that is simply a renamed template without customisation provides false assurance, the controls may not match the organisation's actual systems, risk profile, or regulatory obligations. The table below documents my customisation decisions for each major policy section.

Policy Section	ISO 27001 Provides	SANS Template Provides	Analyst Customised To Add
Purpose	Control objective statement (e.g. 'prevent unauthorised access to information')	Plain-language purpose statement linked to business risk	UK GDPR and Data Protection Act 2018 obligations; health-data risks identified in the risk register; regulatory, operational and patient-safety impacts as business drivers.
Scope	Reference to ISMS scope (Clause 4.3), abstract organisational boundary	Clear list: all employees, contractors, volunteers	Defined clinical, administrative, Staff Wireless and visitor network segments; EHR systems; remote access; employees, contractors and authorised third parties.
Definitions	ISO control vocabulary (e.g. 'information security event')	Simple plain-English definitions	Personal data, special category data, health data, data subject, controller and processor; organisation-specific EHR, VLAN and access-control terminology.
Policy Statements	Relevant Annex A controls selected according to the organisation’s assessed risks	Numbered operational requirements in plain language	Least-privilege access by role and network segment; mandatory MFA for EHR and privileged access; health-data encryption using approved standards; automatic workstation locking; incident escalation and ICO notification within 72 hours where legally required.
Enforcement	ISO 27001 Clauses 9 and 10: performance evaluation, nonconformity, corrective action and continual improvement	Disciplinary action up to termination	Disciplinary action, corrective action, suspension or removal of access, and reporting to the ICO or other relevant regulators where legally required.
Review Cycle	ISO 27001 Clauses 9.3 and 10: management review and continual improvement	Annual review, triggered by incident	Annual review and additional review following a personal-data breach, significant regulatory change, major network change, EHR system change or material change to the risk assessment.

Analyst Note: *My approach was to use ISO 27001:2022 as the compliance framework and for Annex A control mapping, use SANS templates for plain-English language and operational policy structure, and then incorporate UK GDPR, the Data Protection Act 2018, NIST, CIS Controls and the organisation’s specific healthcare, risk and network-segmentation requirements.*

6. Risk Register: Driving Policy Selection

The six policies produced were not chosen arbitrarily, each one was driven by a specific risk entry in the Risk Register. This is the critical link between risk assessment and policy development: every policy in this suite exists because the risk register identified a risk that no existing control was adequately addressing.

Asset	Vulnerability	Threat	Potential Impact	Rating	Policy Produced
Health Data	Excessive privileges and staff access beyond their assigned roles	Insider misuse or accidental or deliberate unauthorised access	Breach of confidentiality, regulatory action, operational disruption and potential harm to patients	**High**	**Policy 1, Health Data Access Control**
Electronic Health Data	Health data is not adequately encrypted at rest or in transit across network segments	Data interception, man-in-the-middle attack or unauthorised disclosure	Exposure of special category data and significant regulatory, operational and reputational impact	**High**	**Policy 2, Health Data Encryption**
EHR System	Single-factor authentication is used to access clinical systems	Credential theft, password attacks or account compromise	Unauthorised access to a large volume of confidential patient records	**High**	**Policy 3, Authentication**
Audit Logs	Incomplete security-event and health-data access logging	Malicious or unauthorised activity remains undetected and lacks a reliable forensic trail	Inability to investigate incidents, identify affected records or demonstrate accountability	**High**	**Policy 4, Audit Logging**
Incident Response Process	No documented personal-data breach assessment, escalation and notification procedure	Delayed, inconsistent or non-compliant response to a personal-data breach	Failure to contain the incident, protect affected individuals or meet applicable UK GDPR and ICO reporting requirements	**High**	**Policy 5, Personal Data Breach Response**
Workstations	No formal acceptable use requirements	Accidental or careless exposure of confidential information	Staff may share accounts, leave health data visible on unattended screens or use unapproved personal devices	**Medium**	**Policy 6, Acceptable Use**

Policy 1	Health Data Access Control Policy	SEC-POL-001

HEALTHCARE CLINICAL & ADMINISTRATIVE CENTRE

HEALTH DATA ACCESS CONTROL POLICY

SEC-POL-001 | Version 1.0 | INTERNAL, RESTRICTED

Policy Owner	Effective Date	ISO 27001 Controls	Template Source
Cybersecurity Analyst / CISO	11 October 2026	A.5.15 | A.5.16 | A.8.2	ISO 27001 + SANS Information Security Policy

Analyst Note: *This policy was developed using ISO 27001:2022 controls A.5.15 (Access Control), A.5.16 (Identity Management), A.5.18 (Access Rights) and A.8.2 (Privileged Access Rights) as the control framework. The SANS Information Security Policy template provided the policy structure. UK GDPR, the Data Protection Act 2018, the organisation's risk register and its segmented network architecture were then incorporated into the policy.*

1.0 OVERVIEW

Health data is among the organisation's most sensitive information and is classified as special category personal data under UK GDPR. Failure to control access could expose the organisation to regulatory action, operational disruption, reputational damage and potential harm to patients. The primary risk addressed by this policy is excessive privilege, where staff members can access health data beyond what their roles require. This policy establishes the access-control framework required to manage that risk.

2.0 PURPOSE

The purpose of this policy is to ensure that access to health data and Electronic Health Record (EHR) systems is granted only to authorised individuals according to the principles of least privilege and role-based access control. All access rights must be documented, approved, reviewed and revoked promptly when no longer required. This policy supports compliance with UK GDPR, the Data Protection Act 2018 and ISO 27001:2022 controls A.5.15, A.5.16, A.5.18 and A.8.2.

3.0 SCOPE

This policy applies to all employees, contractors, volunteers and authorised third parties who access any system, application or physical location containing health data within the Healthcare Clinical & Administrative Centre. It covers all organisational network segments, including VLAN 10, IT; VLAN 20, Patient Services; VLAN 30, Procurement; VLAN 40, Audit & Compliance; VLAN 50, Guest/Visitors; the Staff Wireless network; and all approved remote-access arrangements.

4.0 DEFINITIONS

Health Data: Personal data relating to an individual's physical or mental health, including information concerning healthcare services provided to them.

Special Category Data: Personal data requiring additional protection under UK GDPR, including data concerning an individual's health.

Least Privilege: The principle that users shall receive only the minimum access rights necessary to perform their assigned job functions.

RBAC (Role-Based Access Control): An access-control model in which permissions are assigned to roles and individuals are assigned to roles according to their job functions.

Privileged Access: Access rights exceeding standard user permissions, including system-administration access, database access and clinical-record modification rights.

5.0 POLICY

5.1 ACCESS PROVISIONING: All access to health-data systems shall be provisioned using Role-Based Access Control (RBAC). Access rights shall be assigned to roles rather than directly to individuals. Individuals shall be assigned only to roles matching their documented job functions. No access right shall exceed what is necessary for the assigned role.

5.2 NETWORK ACCESS CONTROL: Each department shall operate within its designated network segment. Employees may access only their assigned departmental VLAN or authorised Staff Wireless network. Cross-VLAN access to systems containing health data requires documented approval from the Information Security Officer and must be limited to the approved purpose and period.

5.3 PRIVILEGED ACCESS: All privileged access to health-data systems, including database-administrator, system-administrator and EHR super-user accounts, shall be documented and individually approved by the CISO or an authorised delegate. Privileged access shall never be shared.

5.4 ACCESS REVIEW: Access rights to health-data systems shall be formally reviewed quarterly by the Information Security Officer and the relevant departmental manager. Access rights that cannot be justified by a current business requirement shall be revoked within five business days.

5.5 JOINERS, MOVERS AND LEAVERS: New staff shall receive approved access rights based on their documented roles. When staff change roles, obsolete access rights shall be removed and new rights provisioned on the effective date of the change. Departing staff shall have all access rights revoked on or before their final working day.

5.6 SHARED ACCOUNTS: Shared accounts are prohibited on systems containing health data. Every authorised user shall use a unique, individually assigned account to maintain a complete and attributable audit trail.

6.0 POLICY COMPLIANCE

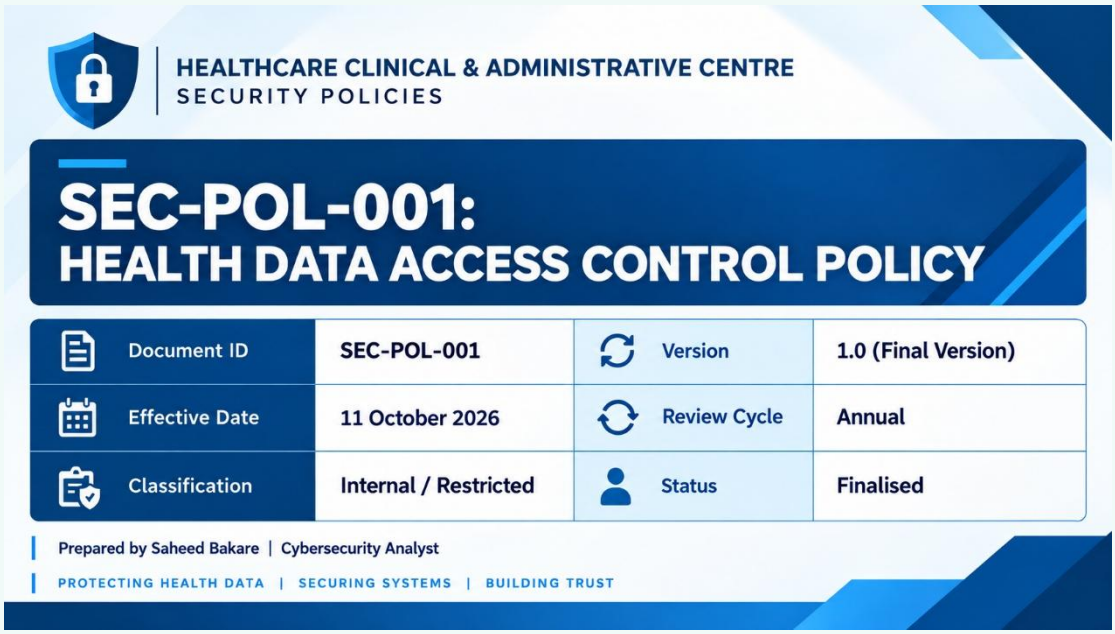
Any violation of this policy may result in disciplinary action, suspension or removal of access, termination of employment or contract, and any other corrective action permitted by organisational procedures and applicable UK law. Suspected violations shall be investigated and documented. Any associated personal-data breach shall be escalated immediately to the Information Security Officer and Data Protection Officer and reported to the ICO within 72 hours where legally required.

7.0 RELATED DOCUMENTS

SEC-POL-002 (Health Data Encryption Policy) | SEC-POL-003 (Authentication & Password Policy) | SEC-POL-004 (Audit Logging & Monitoring Policy) | UK GDPR | Data Protection Act 2018 | ISO 27001:2022 Annex A controls A.5.15, A.5.16, A.5.18 and A.8.2

8.0 REVIEW

This policy shall be reviewed annually. An immediate review shall also be triggered by a health-data access-control breach, a significant change to the organisation's EHR systems or network architecture, a material change to the risk assessment, or a relevant change to UK data-protection legislation or regulatory guidance.



Policy 2	Health Data Encryption Policy	SEC-POL-002

HEALTHCARE CLINICAL & ADMINISTRATIVE CENTRE

Health Data ENCRYPTION POLICY

SEC-POL-002 | Version 1.0 | INTERNAL, RESTRICTED

Policy Owner	Effective Date	ISO 27001 Controls	Template Source
Cybersecurity Analyst / IT Manager	11 October 2026	A.8.12 | A.8.24	ISO 27001 + SANS Data Classification Policy

Analyst Note: *ISO 27001:2022 control A.8.24 (Use of Cryptography) provided the principal control requirement, supported by A.8.12 (Data Leakage Prevention). The SANS Data Classification Policy template provided the policy structure. UK GDPR, the Data Protection Act 2018, NIST guidance, the organisation's risk register and its segmented network architecture were then incorporated into the policy.*

1.0 OVERVIEW

Electronic health data transmitted or stored without appropriate encryption is vulnerable to interception, unauthorised disclosure, loss and theft. Health data is classified as special category personal data under UK GDPR and requires additional protection. Encryption protects the confidentiality of health data during transmission and storage. However, encryption does not remove the organisation's responsibility to assess, document and report a personal-data breach where legally required.

2.0 PURPOSE

The purpose of this policy is to define the minimum encryption requirements for electronic health data in transit and at rest. It ensures that electronic transmissions, storage systems, portable media, backups and remote-access connections containing health data are protected using approved cryptographic controls. This policy supports compliance with UK GDPR, the Data Protection Act 2018 and ISO 27001:2022 controls A.8.12 and A.8.24.

3.0 SCOPE

This policy applies to all electronic health data created, stored, processed or transmitted by the Healthcare Clinical & Administrative Centre. It covers all organisational network segments, EHR systems, email systems, databases, servers, workstations, portable media, backups, the Staff Wireless network and approved remote-access connections to systems containing health data.

4.0 POLICY, ENCRYPTION REQUIREMENTS

4.1 HEALTH DATA IN TRANSIT: All health data transmitted across any network, including inter-VLAN traffic, internet-bound traffic, wireless transmissions and approved remote-access

connections, shall be encrypted using Transport Layer Security (TLS) version 1.2 or higher. TLS 1.0 and TLS 1.1 are deprecated and shall not be used.

4.2 HEALTH DATA AT REST: Health data stored on servers, databases, workstations, backups and portable media shall be encrypted using AES-256 or another cryptographic standard formally approved by the Information Security Officer. Unencrypted health data shall not be stored on laptops, USB drives, tablets or other portable devices.

4.3 EMAIL: Health data shall not be transmitted through standard unencrypted email. Communications containing health data must use an approved secure-messaging platform, encrypted email gateway or another authorised encrypted communication method. Staff shall not forward health data to personal email accounts.

4.4 REMOTE ACCESS: All remote-access connections to systems containing health data shall use an approved VPN with strong encryption and multi-factor authentication. Direct RDP or SSH connections from external networks to internal systems are prohibited unless routed through an approved secure-access service.

4.5 KEY MANAGEMENT: Encryption keys shall be managed by authorised IT personnel. Access to cryptographic keys shall be restricted, documented and reviewed. Keys shall be rotated according to the organisation's approved key-management schedule and immediately replaced where compromise is suspected. All key-management activities shall be logged.

4.6 ENCRYPTION VERIFICATION: The IT Department shall verify quarterly that encryption is active and correctly configured on systems that store or transmit health data. Any system found to be storing or transmitting unencrypted health data shall be isolated where necessary and remediated promptly.

5.0 POLICY COMPLIANCE

Transmission or storage of health data without the encryption required by this policy constitutes a security violation and may result in disciplinary action, suspension or removal of access, termination of employment or contract, and other corrective action permitted by organisational procedures and applicable UK law. Any associated personal-data breach shall be assessed, documented and reported to the ICO where legally required.

6.0 RELATED DOCUMENTS

SEC-POL-001 (Health Data Access Control Policy) | SEC-POL-003 (Authentication & Password Policy) | SEC-POL-004 (Audit Logging & Monitoring Policy) | UK GDPR | Data Protection Act 2018 | NIST Cryptographic Standards and Guidelines | ISO 27001:2022 Annex A controls A.8.12 and A.8.24

Policy 3	Authentication & Password Policy	SEC-POL-003

HEALTHCARE CLINICAL & ADMINISTRATIVE CENTRE

AUTHENTICATION & PASSWORD POLICY

SEC-POL-003 | Version 1.0 | INTERNAL

Policy Owner	Effective Date	ISO 27001 Controls	Template Source
Cybersecurity Analyst / IT Manager	11 October 2026	A.5.17 | A.8.5	ISO 27001 + SANS Password Protection Policy

Analyst Note: *The SANS Password Protection Policy template was used as the primary structural source and adapted to the organisation's UK healthcare environment. Requirements were added for multi-factor authentication, clinical systems, privileged accounts and systems processing health data. The policy is aligned with ISO 27001:2022 controls A.5.17 and A.8.5, with NIST SP 800-63B used as supplementary technical guidance for password and authentication requirements.*

1.0 OVERVIEW

Compromised credentials are a leading cause of security incidents and personal data breaches. Single-factor authentication for systems processing health data presents an unacceptable risk because credentials may be stolen through phishing, brute-force attacks or password reuse. This policy establishes mandatory multi-factor authentication and secure password requirements aligned with ISO 27001:2022 and NIST SP 800-63B guidance.

2.0 PURPOSE

The purpose of this policy is to establish minimum authentication requirements for all accounts accessing systems that process health data, require multi-factor authentication (MFA) for clinical and administrative systems, and define secure password creation, management and protection requirements. These controls support compliance with the UK GDPR, Data Protection Act 2018, ISO 27001:2022 controls A.5.17 and A.8.5, and NIST SP 800-63B guidance.

4.0 POLICY, AUTHENTICATION REQUIREMENTS

4.1 MULTI-FACTOR AUTHENTICATION (MFA): MFA is mandatory for all privileged accounts, remote-access connections and access to systems processing health data. This includes electronic health record systems, servers on VLAN 10 and VLAN 20, VPN connections and the Splunk SIEM platform. MFA shall use at least two authentication factors: something the user knows, something the user possesses, or something the user is. Authenticator applications or hardware security tokens shall be used where available. SMS-based authentication shall only be used as a temporary measure while migration to a more secure method is completed.

4.2 PASSWORD LENGTH: All passwords for accounts with access to health data must be a minimum of 14 characters. System administrator and privileged accounts must use a minimum of 16 characters.

4.3 PASSWORD REQUIREMENTS: Passwords shall be long, unique and difficult to guess. Users should use passphrases containing unrelated words where appropriate. Passwords must not contain easily guessed information, common passwords, organisation names, usernames or known compromised credentials. Password reuse across personal and organisational accounts is prohibited.

4.4 PASSWORD CHANGES: Passwords shall be changed immediately when compromise is known or suspected, when instructed by the IT Department, or following an account-recovery event. Routine password expiration shall not be required unless justified by a documented risk assessment. Previously compromised passwords must not be reused.

4.5 PASSWORD STORAGE & SHARING: Passwords shall never be shared between users. Passwords shall not be written on physical media or stored in plain text files. All staff are encouraged to use an organisation-approved password manager. Sharing of any account credentials is a disciplinary offence.

4.6 ACCOUNT LOCKOUT: Accounts shall be locked after 5 consecutive failed login attempts. Locked accounts shall require manual reset by the IT Department after verification of the user's identity. This threshold applies to all systems processing health data.

4.7 DEFAULT CREDENTIALS: All default manufacturer credentials on any device or system shall be changed before the device or system is connected to the network. Default credentials on network devices, servers, or applications are a critical security failure.

5.0 POLICY COMPLIANCE

Failure to comply with MFA and password requirements constitutes a serious policy violation and may result in account suspension pending investigation. Sharing credentials may lead to disciplinary action, including termination of employment or contract. Any suspected credential compromise or personal data breach must be reported immediately to the IT Department and Data Protection Officer. Reportable personal data breaches shall be assessed and notified to the Information Commissioner’s Office within 72 hours, where required under the UK GDPR.

Policy 4	Audit Logging & Monitoring Policy	SEC-POL-004

HEALTHCARE CLINICAL & ADMINISTRATIVE CENTRE

AUDIT LOGGING & MONITORING POLICY

SEC-POL-004 | Version 1.0 | INTERNAL, RESTRICTED

Policy Owner	Effective Date	ISO 27001 Controls	Template Source
Cybersecurity Analyst / IT Manager	11 October 2026	A.8.15 | A.8.16	ISO 27001 + SANS Audit Policy Template

Analyst Note: *ISO 27001:2022 controls A.8.15 (Logging) and A.8.16 (Monitoring Activities) provided the control framework. The SANS Audit Policy template was used as the primary structural source and adapted to the organisation's UK healthcare environment. Requirements were added for recording access to systems processing health data, detecting suspicious activity, integrating logs with the Splunk SIEM platform and retaining audit records in accordance with the organisation's approved retention requirements. The policy also supports the security and accountability requirements of the UK GDPR and Data Protection Act 2018.*

1.0 OVERVIEW

Without comprehensive audit logging of access to health data, the organisation cannot effectively detect unauthorised activity, investigate security incidents or demonstrate compliance with its legal and regulatory responsibilities. Systems processing health data must implement technical and organisational measures that record and monitor relevant security events. This policy establishes mandatory requirements for logging, monitoring, reviewing, protecting and retaining audit records in accordance with ISO 27001:2022, the UK GDPR and the Data Protection Act 2018.

4.0 POLICY, LOGGING & MONITORING REQUIREMENTS

4.1 **MANDATORY LOGGING:** The following events shall be logged for all systems processing health data: successful and failed user login attempts; user logout events; access to health records, including viewing, creating, modifying and deleting records; privilege-escalation events; administrative configuration changes; system start-up and shutdown events; and remote-access connections.

4.2 LOG INTEGRITY: All audit logs shall be stored in a tamper-evident format. Logs shall be written to a centralised logging system (SIEM, Splunk Enterprise) that is isolated from the systems generating the logs. Staff shall not have the ability to modify or delete audit logs from systems they operate.

4.3 LOG RETENTION: Audit logs relating to access to health data shall remain immediately searchable on the SIEM platform for a minimum of 90 days. Archived logs shall be retained for a minimum of six years in accordance with the organisation's approved records-retention schedule. Access to archived logs shall be restricted, and the logs shall be protected against unauthorised modification or deletion.

4.4 MONITORING: The Information Security team shall review audit logs relating to access to health data at least monthly. The Splunk SIEM platform shall generate automated alerts for suspicious activity, including more than five failed login attempts against a system processing health data, access outside normal business hours (08:00–18:00) by a standard user, bulk access to more than 50 health records in a single session, privilege-escalation events and access from an unrecognised device or IP address.

4.5 RESPONSE: Any suspected unauthorised access identified through log review or a SIEM alert shall be investigated within 24 hours of detection. Investigations and response actions shall be documented. Where an investigation confirms unauthorised access to personal data, the organisation's Breach Notification Policy (SEC-POL-005) shall be activated and the Data Protection Officer shall be notified.

4.6 SIEM PLATFORM: Splunk Enterprise is the organisation's designated SIEM platform. All systems processing health data on VLAN 10 and VLAN 20 shall be configured to forward relevant Windows Security event logs, including Event Codes 4624, 4625, 4634, 4648 and 4740, to the Splunk indexer through the Splunk Universal Forwarder.

Policy 5	Breach Notification Policy	SEC-POL-005

HEALTHCARE CLINICAL & ADMINISTRATIVE CENTRE

BREACH NOTIFICATION POLICY

SEC-POL-005 | Version 1.0 | INTERNAL, CRITICAL

Policy Owner	Effective Date	ISO 27001 Controls	Template Source
Cybersecurity Analyst / CISO / Legal	11 October 2026	A.5.24 | A.5.26	ISO 27001 + SANS Security Response Plan Policy

Analyst Note: *ISO 27001:2022 controls A.5.24 (Information Security Incident Management Planning and Preparation) and A.5.26 (Response to Information Security Incidents) provided the control framework. The SANS Security Response Plan Policy template was used as the primary structural source and adapted to the organisation's UK healthcare environment. UK GDPR Articles 33 and 34, the Data Protection Act 2018 and current Information Commissioner's Office guidance were used to establish the breach-assessment, documentation and notification requirements, including the 72-hour ICO reporting timeframe.*

1.0 OVERVIEW

A personal data breach is both a security incident and a potential regulatory event. Where a breach is likely to result in a risk to individuals' rights and freedoms, the organisation must notify the Information Commissioner's Office without undue delay and, where feasible, within 72 hours of becoming aware of it. Where the risk is high, affected individuals must also be informed without undue delay. This policy defines what constitutes a personal data breach, how breaches must be assessed and documented, who must be notified and the required notification timeframes.

4.0 POLICY, BREACH NOTIFICATION REQUIREMENTS

4.1 BREACH DEFINITION: A personal data breach is a breach of security that results in the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data. This includes incidents affecting the confidentiality, integrity or availability of health data and other personal information processed by the organisation.

4.2 BREACH ASSESSMENT: Upon discovery of a suspected personal data breach, the Information Security Officer and Data Protection Officer shall conduct and document an immediate risk assessment. The assessment shall consider the nature, sensitivity and volume of the personal data involved; the number and characteristics of affected individuals; whether individuals can be identified; the possible consequences of the breach; and the effectiveness of any measures taken to contain or reduce the risk.

4.3 INTERNAL NOTIFICATION: All staff, contractors and authorised third parties must report any suspected or confirmed personal data breach immediately to the Information Security Officer and Data Protection Officer. The report must include all information currently available. Staff must not delay reporting while attempting to investigate the incident independently.

4.4 ICO NOTIFICATION: Where a personal data breach is likely to result in a risk to the rights and freedoms of individuals, the Data Protection Officer shall notify the Information

Commissioner's Office without undue delay and, where feasible, within 72 hours of becoming aware of the breach. If the initial notification is incomplete, further information shall be provided in phases without undue delay. Any notification made after 72 hours must include the reasons for the delay.

4.5 INDIVIDUAL NOTIFICATION: Where a personal data breach is likely to result in a high risk to the rights and freedoms of affected individuals, the organisation shall inform those individuals directly and without undue delay. The notification shall use clear and plain language and describe the nature of the breach, the likely consequences, the measures taken or proposed, protective actions individuals should take and the contact details of the Data Protection Officer.

4.6 ENCRYPTION AND RISK ASSESSMENT: Encryption, pseudonymisation and other security controls shall be considered when assessing the risk created by a personal data breach. Where compromised data was encrypted and the encryption keys remained secure, the risk to individuals may be reduced. However, encryption shall not automatically remove the requirement to document, assess or escalate the breach.

4.7 BREACH LOG: All suspected and confirmed personal data breaches shall be recorded in the organisation's breach log, regardless of whether notification to the ICO or affected individuals is required. Records shall include the facts of the breach, its effects, the risk assessment, notification decisions, containment measures and remedial action taken. Records shall be retained in accordance with the organisation's approved records-retention schedule.

5.0 POLICY COMPLIANCE

Failure to report a suspected or confirmed personal data breach immediately may constitute a serious policy violation and may result in disciplinary action, including termination of employment or contract. Deliberately concealing, altering or destroying information relating to a breach is prohibited. Failure by the organisation to comply with applicable breach-notification requirements may result in investigation or regulatory enforcement by the Information Commissioner's Office.

Policy 6	Acceptable Use Policy	SEC-POL-006

HEALTHCARE CLINICAL & ADMINISTRATIVE CENTRE

ACCEPTABLE USE POLICY

SEC-POL-006 | Version 1.0 | INTERNAL, ALL STAFF

Policy Owner	Effective Date	ISO 27001 Controls	Template Source
Cybersecurity Analyst / HR Manager	11 October 2026	A.6.3 | A.5.1	ISO 27001 + SANS Acceptable Use Policy Template

Analyst Note: *The SANS Acceptable Use Policy template was used as the primary structural source and adapted to the organisation's UK healthcare environment. Requirements were added for clinical workstations, systems processing health data, approved devices, encrypted portable media, remote working, the Staff Wireless network and visitor VLAN restrictions. ISO 27001:2022 controls A.6.3 (Information Security Awareness, Education and Training) and A.5.1 (Policies for Information Security) provide the control framework. The policy also supports compliance with the UK GDPR and Data Protection Act 2018.*

1.0 OVERVIEW

The Healthcare Clinical & Administrative Centre's information systems, network resources and data support the delivery of healthcare services and administrative operations. All staff are responsible for using these resources appropriately, protecting health data and other personal information, and avoiding actions that could expose information, compromise system security or breach organisational policies and applicable UK data-protection legislation. This policy defines acceptable and prohibited uses of the organisation's systems, networks, devices and data.

4.0 POLICY, ACCEPTABLE USE REQUIREMENTS

4.1 AUTHORISED USE: Organisation systems, networks, and devices shall be used primarily for business purposes. Limited, incidental personal use is permitted provided it does not interfere with work duties, consume significant network bandwidth, or involve access to material that is illegal, offensive, or contrary to organisational values.

4.2 PROHIBITED USES: The following activities are strictly prohibited on organisational systems and networks: accessing, downloading or distributing unlawful or unauthorised material; installing unauthorised software or applications; connecting personal devices to clinical or restricted VLANs, including VLAN 10 and VLAN 20, without IT approval and mobile-device-management enrolment; accessing the dark web, peer-to-peer file-sharing networks or gambling websites; sharing login credentials with another person; attempting to access systems or information outside the user's authorised role; and bypassing or disabling security controls.

4.3 CLINICAL WORKSTATION REQUIREMENTS: Workstations in clinical areas on VLAN 10 and VLAN 20 shall automatically lock after five minutes of inactivity, as enforced through Group Policy. Clinical workstations shall not be used for personal internet browsing or entertainment. Health data displayed on screen must not be visible to visitors or unauthorised persons. The

clean-desk and clear-screen requirements apply to all health data and personal information before a workstation is left unattended.

4.4 HEALTH DATA AND DEVICE HANDLING: Health data shall not be printed unless operationally necessary. Printed documents containing health data must be collected immediately from printers and stored securely or disposed of using an approved confidential-waste process. Health data must not be photographed, copied or transferred to personal devices. Transfer to portable media, including USB drives and external disks, is prohibited unless the media is organisation-approved, encrypted and authorised by the IT Department.

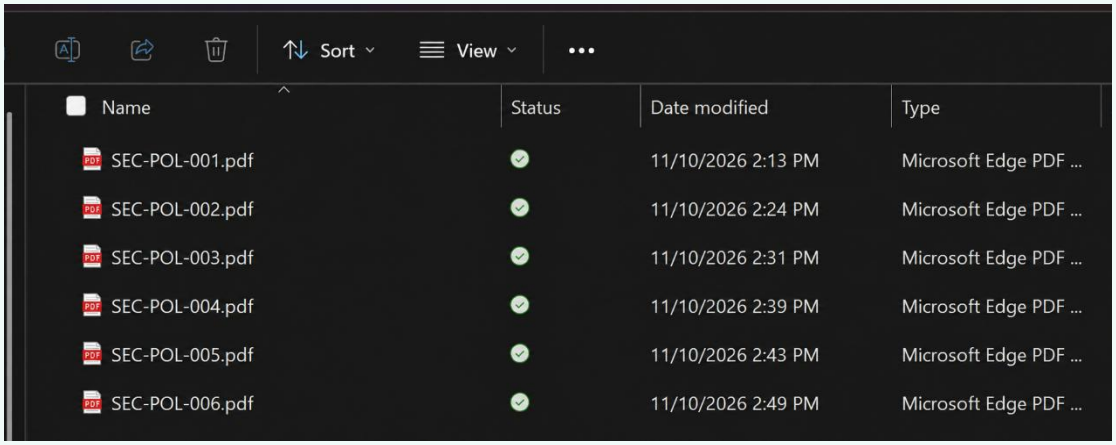
4.5 GUEST AND VISITOR NETWORK: Visitors and guests shall use the Guest VLAN (VLAN 50) exclusively. Devices connected to the Guest VLAN must not have access to clinical systems, health data or internal organisational resources, as enforced through firewall access-control rules. Staff must not provide visitors with credentials for the Staff Wireless network or any VLAN other than VLAN 50.

4.6 REMOTE WORKING: Staff working remotely must connect to organisational systems through the approved VPN using multi-factor authentication. Health data and other organisational information must not be stored on personal devices. Screen sharing during video calls is permitted only where all participants are authorised and only the information necessary for the meeting is displayed.

4.7 POLICY ACKNOWLEDGEMENT: All staff with access to organisational systems and information shall read, understand and formally acknowledge this policy annually. New staff must acknowledge the policy before access is granted. Policy-acknowledgement records shall be maintained by Human Resources and reviewed by the Information Security team.

5.0 POLICY COMPLIANCE

Violations of this policy shall be assessed individually and may result in a verbal warning, written warning, suspension of access or termination of employment or contract, depending on severity. Any violation resulting in the suspected exposure, loss or unauthorised disclosure of personal data shall be treated as a potential personal data breach and escalated under the Breach Notification Policy (SEC-POL-005). The organisation reserves the right to monitor activity on its systems and networks for security, operational and policy-compliance purposes, subject to applicable law and organisational procedures.



13. ISO 27001 Annex A Control Mapping, All 6 Policies

The table below provides the complete ISO 27001 Annex A compliance evidence for the full policy suite, showing exactly which Annex A controls each policy satisfies. This table is the primary deliverable for an ISO 27001 auditor reviewing the organisation's policy documentation against the Annex A requirements.

Annex A Control	Control Name	Requirement	Policy Satisfying It
A.5.1	Policies for Information Security	Policies shall be defined and reviewed at planned intervals	All 6 policies, SEC-POL-001 to 006
A.5.15	Access Control	Rules for access control shall be established based on business and security requirements	SEC-POL-001 (Health Data Access Control)
A.5.16	Identity Management	Lifecycle of identities shall be managed	SEC-POL-001 (JML process)
A.5.17	Authentication Information	Allocation and management of authentication information shall be controlled	SEC-POL-003 (Authentication & Password)
A.5.24	Information Security Incident Management	Information security incident management responsibilities shall be planned	SEC-POL-005 (Breach Notification)
A.5.26	Response to Information Security Incidents	Information security incidents shall be responded to in accordance with documented procedures	SEC-POL-005 (Breach Response)
A.6.3	Information Security Awareness, Education and Training	Personnel shall receive awareness and training	SEC-POL-006 (Policy Acknowledgement)
A.8.2	Privileged Access Rights	Allocation and use of privileged access rights shall be restricted	SEC-POL-001 (RBAC & least privilege)
A.8.5	Secure Authentication	Secure authentication technologies and procedures shall be implemented	SEC-POL-003 (MFA mandate)
A.8.12	Data Leakage Prevention	Data leakage prevention measures shall be applied to systems, networks and devices processing sensitive information	SEC-POL-002 (Health Data Protection)
A.8.15	Logging	Event logs recording user activities shall be produced, stored, protected and analysed	SEC-POL-004 (Audit Logging)

A.8.16	Monitoring Activities	Networks, systems and applications shall be monitored	SEC-POL-004 (SIEM monitoring)
A.8.24	Use of Cryptography	Rules for the use of cryptography shall be defined and implemented	SEC-POL-002 (Health Data Encryption)

14. Policy Suite Implementation Plan

Producing the policy documents is only the first step. The following implementation plan defines how each policy is operationalised, moving from a document on the intranet to a live, enforced control.

Policy	Key Implementation Action	Technical Control Required	Owner	Timeline
SEC-POL-001Access Control	Conduct RBAC role definition per VLAN; remove excess access	Active Directory RBAC groups; quarterly access review process	IT Manager	**30 days**
SEC-POL-002Encryption	Audit all systems processing health data for encryption compliance; deploy TLS 1.2 or higher.	TLS configuration on servers; BitLocker/AES-256 on workstations; VPN	IT Manager	**30 days**
SEC-POL-003Authentication	Enforce MFA across all clinical systems, privileged accounts and remote-access connections; update the password policy.	Microsoft Entra ID MFA; Active Directory Group Policy; minimum 14-character passwords; compromised-password screening	IT Manager	**14 days**
SEC-POL-004Audit Logging	Configure Splunk Universal Forwarder on all systems processing health data; configure SIEM alerts	Splunk Enterprise SIEM; UF on VLAN 10/20 servers; alert thresholds	Cyber Analyst	**21 days**
SEC-POL-005Breach Notification	Brief incident response team; create breach log template; test procedure	Breach log; ICO breach-reporting process; individual notification templates	CISO / Legal	**7 days**
SEC-POL-006Acceptable Use	Distribute to all staff; collect signed acknowledgements; deliver training	Digital acknowledgement system; HR records; annual training schedule	HR + Cyber Analyst	**21 days**

15. Key Lessons, What the Analyst Learned

#	Lesson	Detail
L-1	**Templates accelerate quality, but customisation is where the real work is**	The ISO 27001 and SANS templates provided structure, terminology and completeness assurance. However, each policy gained its real value through customisation, including UK GDPR and Data Protection Act 2018 requirements, VLAN-specific controls and healthcare-specific risks. A template without customisation may introduce controls that do not reflect the organisation's actual environment.
L-2	**ISO 27001 and SANS templates are complementary, not competing**	ISO 27001 Annex A tells you WHAT controls are required. SANS templates show you HOW to write those controls in language staff can understand and auditors can verify. Using both together produces policies that are simultaneously technically rigorous and operationally readable, a combination neither template achieves alone.
L-3	**The risk register is the policy architecture document**	Every policy in this suite exists because a specific row in the risk register had no adequate control. Building the policy suite from the risk register means there are no orphan policies (policies that don't address a known risk) and no unaddressed risks (risks without a policy control). This traceability provides the evidence required during ISO 27001 audits and UK data-protection compliance reviews.
L-4	**Encryption of health data is essential for reducing breach risk**	The SANS Data Classification template and ISO 27001 control A.8.24 both support the appropriate use of cryptography. Encrypting health data at rest and in transit reduces the risk of unauthorised disclosure if systems or devices are compromised. Adding this requirement to SEC-POL-002 transforms encryption from a general compliance measure into an important part of the organisation's breach-risk management strategy.
L-5	**Policies are living documents, the review cycle is as important as the initial draft**	A policy that is written once and filed is not a security control, it is a document. The annual review requirement, triggered-review conditions (regulatory update, new VLAN, clinical-system change or security incident), and version control built into every policy ensure that the suite evolves with the organisation's risk landscape rather than becoming stale and irrelevant within 12 months.

16. Screenshot Evidence Index

#	Screenshot Caption	Section	Source
1	ISO 27001:2022 Annex A Controls List (Source Document)	2, Template Selection	ISO 27001 Standard / Reference Site
2	SANS Institute, Policy Template Library (sans.org)	2, Template Selection	sans.org/information-security-policy
3	Risk Register, All 6 Risks Mapped to Policies	6, Risk Register	Risk Register Spreadsheet
4	SEC-POL-001, Signed Health Data Access Control Policy (Final)	7, Policy 1	Policy Document
5	Active Directory, RBAC Role Groups per VLAN (Implementation)	14, Implementation Plan	Active Directory Users & Computers
6	SEC-POL-002, Health Data Encryption Policy (Final)	8, Policy 2	Policy Document
7	TLS/Encryption Verification, Server Certificates Active	14, Implementation Plan	IIS Manager / SSL Tool
8	SEC-POL-003, Authentication & Password Policy (Final)	9, Policy 3	Policy Document
9	Microsoft Entra ID / Active Directory, MFA Enforced on Clinical User Accounts	14, Implementation Plan	Microsoft Entra Admin Centre / Active Directory
10	SEC-POL-004, Audit Logging & Monitoring Policy (Final)	10, Policy 4	Policy Document
11	Splunk SIEM Dashboard with Health-Data Access Alerts Active	14, Implementation Plan	Splunk Enterprise SIEM
12	SEC-POL-005, Breach Notification Policy (Final)	11, Policy 5	Policy Document
13	SEC-POL-006, Acceptable Use Policy (Final with Staff Signatures)	12, Policy 6	Policy Document + HR Records
14	All 6 Policies, Complete Policy Suite Overview	12, Policy Suite Complete	Policy Documents Folder
15	ISO 27001 Annex A Compliance Evidence, All 6 Policies Mapped	13, ISO Mapping Table	Compliance Evidence Document

End of Security Policy Development Documentation

UK Healthcare Clinical & Administrative Centre | ISO 27001 & SANS Templates | 6 Policies | UK GDPR | Data Protection Act 2018